

IADE · UNIVERSIDADE EUROPEIA

PROJETO DE DESENVOLVIMENTO WEB · FASE II

NextBid

Plataforma de leilões online com gamificação e geolocalização. Relatório de ideação, prototipagem e implementação Alfa.

EQUIPA

Rodrigo Canto
Rodrigo Daibert
Marco Fonseca
Daniel Paulo

FASE



IDEAÇÃO · ALFA

REPOSITÓRIO

[github.com/
rodrigocanto05/NextBid](https://github.com/rodrigocanto05/NextBid)

DOCUMENTO

Relatório Técnico

Índice

01	Identificação & Introdução	03
02	Objetivos & Funcionalidades	04
03	Casos de Uso e Modelo de Domínio	05
04	Arquitetura de Informação · Tasks · Flows	08
05	Wireframes	10
06	Design System & Interfaces Finais	13
07	Base de Dados	16
08	API REST	17
09	Esquema da Solução Técnica	19
10	Estado Atual & Próximos Passos	21

Este documento descreve a evolução do NextBid ao longo da Fase II do projeto, desde a modelação UML e arquitetura de informação até à versão Alfa funcional, passando pelo design system, base de dados e camada de API.

Identificação & Contexto

Após a fase de pesquisa e definição de requisitos, o NextBid avançou para a sua segunda etapa — Ideação e Prototipagem — marcando a transição da concetualização para a materialização técnica e visual do projeto.

ENQUADRAMENTO ACADÉMICO

O NextBid é um projeto desenvolvido no âmbito da unidade curricular de Projeto de Desenvolvimento Web, na Universidade Europeia · IADE, e prolonga o trabalho iniciado na Fase I, onde foram identificados o problema, o público-alvo e os requisitos funcionais do sistema. A presente Fase II concentra-se em traduzir esses requisitos em artefactos tangíveis: diagramas UML, mockups de alta fidelidade, base de dados normalizada, API REST documentada e uma versão Alfa onde o fluxo principal de dados pode ser validado de ponta a ponta. A equipa é composta por quatro elementos — Rodrigo Canto, Rodrigo Daibert, Marco Fonseca e Daniel Paulo — com responsabilidades distribuídas entre ideação, design, backend e frontend.

DESCRIÇÃO DA SOLUÇÃO

O NextBid é uma aplicação web que permite a criação, gestão e participação em leilões online. A solução assenta numa separação clara entre frontend e backend, garantindo modularidade e escalabilidade: o cliente é construído em HTML, CSS e JavaScript Vanilla, enquanto o servidor expõe uma API REST em PHP que dialoga com uma base de dados relacional MySQL/MariaDB. O sistema permite aos utilizadores interagir com dados em tempo real, sendo estes processados no servidor e apresentados na interface através de chamadas assíncronas com a Fetch API.

VISÃO E DIFERENCIAÇÃO

O objetivo central é garantir não só o funcionamento do sistema de leilões, mas também uma experiência interativa suportada por dados dinâmicos e por funcionalidades adicionais de gamificação — em particular a Caça ao Tesouro com integração geográfica, que recompensa os utilizadores com pontos de experiência sempre que validam a sua presença num ponto de interesse via GPS ou QR. Esta camada lúdica posiciona o NextBid como uma plataforma que vai além do leilão tradicional, transformando a participação numa experiência social, exploratória e progressiva.

REPOSITÓRIO E VERSIONAMENTO

Todo o código produzido durante a Fase II encontra-se disponível em github.com/rodrigocanto05/NextBid, com histórico de commits que documenta a evolução do trabalho e permite a auditoria das contribuições individuais. O repositório alberga frontend, backend, scripts SQL de inicialização da base de dados e a documentação técnica de apoio, incluindo o esquema OpenAPI e o relatório complementar relatório_BD.md.

Objetivos da Fase II

Esta fase foi estruturada em torno de seis grandes objetivos que orientaram o trabalho da equipa, do diagrama UML à versão Alfa funcional, garantindo que o produto entregue tem fundação técnica e validação visual.

OBJETIVOS ESTRATÉGICOS

A Fase II procurou consolidar três frentes em paralelo: a frente analítica, com a elaboração em UML dos casos de uso e do modelo de domínio; a frente visual, com o desenvolvimento de mockups de alta fidelidade no Figma e a criação de um Web Design System reutilizável; e a frente técnica, com a implementação da infraestrutura de backend em PHP e da base de dados, bem como a entrega de uma versão Alfa que valida a integração entre frontend e backend. Todo este trabalho foi apoiado por testes com utilizadores que validaram a coerência da arquitetura de informação e o vocabulário usado nos menus.

FUNCIONALIDADES CORE

O sistema de Autenticação cobre o registo e o login com encriptação bcrypt das passwords e gestão de sessão por token, suportando logout do dispositivo atual ou de todos os dispositivos. O Sistema de Licitação aceita lances de forma assíncrona, validando o valor face ao licitador atual antes de persistir a operação. A Caça ao Tesouro estende o produto com eventos georreferenciados que distribuem XP. A Gestão de Leilões implementa o ciclo CRUD completo — criar, listar, detalhar e cancelar — e a Persistência garante que toda a informação manipulada no frontend é refletida na base de dados, eliminando estados voláteis no cliente.

FUNCIONALIDADES SECUNDÁRIAS

Como complemento ao núcleo funcional, foi preparada a infraestrutura para integração de mapas com Leaflet.js, que será usada na visualização de leilões e eventos por proximidade geográfica. O dashboard estatístico ficou pré-instanciado para análises futuras — médias de lances por leilão, tendências temporais e ranking de categorias mais ativas. As notificações em tempo real, embora ainda parciais, já dispõem do modelo de dados (notifications) e dos endpoints REST que sustentarão o módulo na iteração seguinte.

CRITÉRIO DE PRONTO PARA ALFA

A equipa estabeleceu como critério mínimo para considerar a versão Alfa concluída a possibilidade de um utilizador novo se registar, autenticar, navegar pela listagem de leilões, consultar o detalhe de um leilão e submeter um lance, com toda a operação a chegar à base de dados e a refletir-se na interface após uma resposta JSON do servidor. Este fluxo foi atingido e serve de base para os incrementos planeados para a Fase III.

Casos de Uso & Atores

A lógica de negócio foi modelada em UML, traduzindo as regras estabelecidas na Fase I em esquemas técnicos que serviram de ponte direta para a base de dados e para os endpoints da API.

MODELAÇÃO UML

Antes de avançar para a implementação, foi indispensável formalizar o comportamento esperado do sistema. Os diagramas de Casos de Uso identificam quem interage com a aplicação e o que cada ator pode fazer; o Modelo de Domínio identifica as entidades, os seus atributos e as relações entre elas. Em conjunto, estes dois artefactos sustentam todas as decisões de design subsequentes — desde a estrutura de tabelas até à divisão de endpoints REST — e garantem que a equipa partilha uma linguagem comum para discutir requisitos.

ATORES DO SISTEMA

O Visitante representa o utilizador não autenticado: pode consultar leilões ativos, navegar pelo mapa da Caça ao Tesouro e visualizar perfis públicos, mas não pode licitar nem participar em eventos. O Utilizador autenticado é o ator principal — pode licitar, criar leilões, depositar e movimentar saldo na carteira, participar em eventos de gamificação e avaliar vendedores. O Administrador detém acesso total ao sistema, sendo responsável pela gestão de categorias e pela criação de eventos de Caça ao Tesouro, configurando coordenadas, raio de validação e XP atribuído.

CASOS DE USO POR MÓDULO

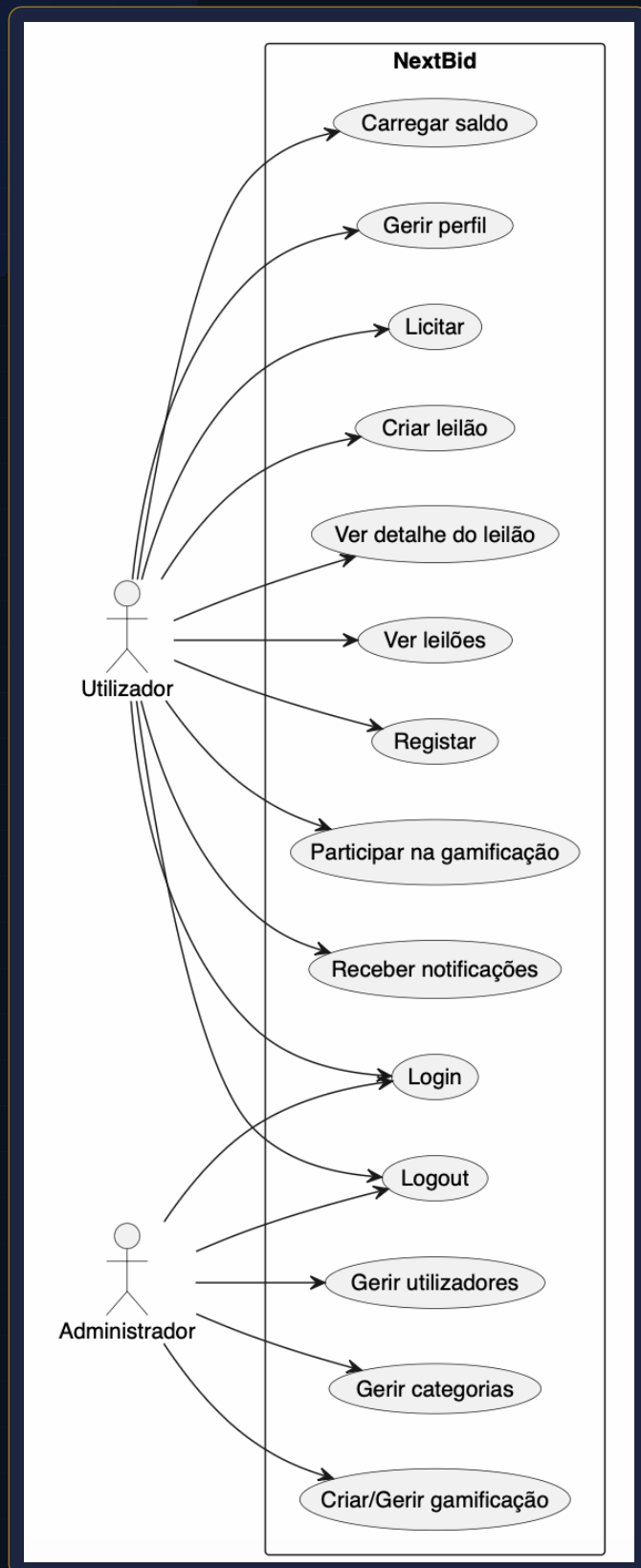
No módulo de Autenticação, o sistema permite registar conta com validação de idade mínima de 18 anos, iniciar sessão e terminar sessão de forma localizada ou global. No módulo de Leilões, é possível criar, listar com filtros por categoria e GPS, ver detalhe, licitar, cancelar leilões sem lances e consultar o histórico de ganhos. A Carteira disponibiliza consulta de saldo, depósitos e extracto de transações, com cada movimento gravado num ledger imutável.

CASOS DE USO DE GAMIFICAÇÃO E PERFIL

A Caça ao Tesouro contempla a exploração de pontos no mapa, a participação em eventos e a reclamação de pontos via GPS ou QR. O módulo de Perfil expõe edição de dados pessoais, consulta de XP e nível, leaderboard global e a possibilidade de avaliar vendedores após uma transação. A Comunicação concentra o chat por leilão e as notificações, e a Administração agrupa a gestão de categorias e a criação de eventos de gamificação, restringida ao papel de Administrador.

Diagrama de Casos de Uso

Representação gráfica das interações entre os três atores e os módulos da aplicação. A leitura faz-se de cima para baixo, seguindo as ações disponíveis para cada papel — do Utilizador, com acesso ao núcleo do produto, até ao Administrador, com responsabilidades adicionais sobre categorias e gamificação.



Modelo de Domínio

Estruturação das entidades centrais do sistema e respectivas relações. O modelo serviu de base direta ao esquema da base de dados relacional e às operações expostas pela API REST.

NÚCLEO DO DOMÍNIO

A entidade User concentra os dados de identificação, autenticação e progresso de gamificação. À sua volta orbitam Product (cada leilão é representado como um produto com lance inicial, duração, localização GPS e estado), Bid (cada lance individual com valor, autor e timestamp) e Transaction (movimentos de carteira, sejam depósitos, retenções por lance ou pagamentos finais). Esta tríade — utilizador, produto, lance — sustenta todo o ciclo de vida do leilão e é a fronteira mais movimentada de toda a aplicação.

ENTIDADES DE CLASSIFICAÇÃO E SUPORTE

Category permite organizar os leilões em hierarquias temáticas e simplifica filtros e estatísticas. ProductAttribute associa pares chave-valor a cada leilão, permitindo descrever atributos heterogêneos (quilometragem, ano, dimensões, condição) sem alterar o esquema. ProductImage guarda as imagens submetidas, com indicação da imagem primária. AuthToken armazena os tokens emitidos pelo servidor de autenticação, permitindo que cada dispositivo tenha a sua própria sessão e que o utilizador possa revogar acessos individualmente.

ENTIDADES DE GAMIFICAÇÃO E COMUNICAÇÃO

Gamification descreve cada evento de Caça ao Tesouro (coordenadas, raio, XP, código de validação). GamificationClaim regista quem reclamou pontos em cada evento. XPLog mantém o histórico de ganhos, enquanto XPLevel define os limiares para cada nível, mantendo a regra de progressão fora do código aplicacional. Notification cobre os alertas em tempo real e Review concentra as avaliações que os compradores deixam a vendedores após cada transação concluída.

RELAÇÃO COM A BASE DE DADOS

Cada uma destas entidades dá origem a uma tabela MySQL com chaves primárias auto-incrementadas, chaves estrangeiras explícitas e índices nos campos mais consultados. O modelo está normalizado até à 3ª Forma Normal — sem dependências transitivas — e o detalhe completo do schema físico, incluindo datatypes e constraints, encontra-se documentado em relatório_BD.md, mantido em paralelo com o presente relatório.

Arquitetura de Informação

A navegação foi organizada em torno do leilão como entidade central — tudo o que o utilizador faz orbita esse núcleo, e o número de cliques entre intenção e ação foi minimizado.

MAPA DE NAVEGAÇÃO

A homepage funciona como porta de entrada e ponto de retorno: a partir dela, o utilizador acede ao separador de Leilões — onde encontra a listagem com filtros por categoria e por proximidade GPS, e a partir do qual abre o detalhe de cada leilão para licitar, conversar no chat e consultar atributos. Em paralelo, dispõe do separador Mapa / Caça ao Tesouro, do Perfil — que aloja Os Meus Leilões, Carteira e XP & Leaderboard — e do fluxo dedicado de Autenticação, com login e registo. Toda a estrutura está pensada para ser percorrida em três ou menos cliques entre quaisquer dois pontos.

TREE TESTING

A coerência da estrutura foi validada com sessões de Tree Testing, em que se pediu aos participantes que localizassem funcionalidades específicas apenas com base na hierarquia de menus, sem ver o design final. O exercício revelou pequenas ambiguidades na nomenclatura — por exemplo, entre "Leilões Ativos" e "Os Meus Leilões" — que foram corrigidas, e permitiu confirmar que o agrupamento por intenção (comprar, vender, jogar, gerir conta) era preferível a um agrupamento meramente funcional.

USER TASKS

As tarefas mais frequentes foram mapeadas a três personas. O Comprador explora leilões, licita e acompanha lances, recebe notificações de estado, gere o saldo da carteira e participa na Caça ao Tesouro como atividade complementar. O Vendedor cria leilões, acompanha as suas listagens ativas, cancela leilões que ainda não tenham lances e consulta as avaliações que os compradores lhe atribuíram. As tarefas gerais — registar conta, autenticar, editar perfil, ver XP e leaderboard, usar o chat de leilão e avaliar um vendedor — são partilhadas por todos os utilizadores autenticados, independentemente de estarem a comprar ou a vender.

Fluxos Críticos

Cinco fluxos críticos cobrem o ciclo de vida do utilizador na plataforma. Cada um foi desenhado de forma a manter o utilizador informado em cada passo e a evitar pontos mortos onde a ação não fosse imediatamente possível.

PARTICIPAÇÃO NUM LEILÃO

O utilizador entra na homepage e aplica filtros pela categoria desejada ou pelo raio geográfico em torno da sua posição. Ao escolher um leilão, é levado para o ecrã de detalhe, onde verifica o saldo disponível na carteira; se o saldo for insuficiente para licitar, o sistema oferece a opção de depositar imediatamente sem sair do contexto, abrindo um modal sobreposto que evita perder o progresso da consulta. Após submeter o lance, recebe uma notificação a confirmar a operação, e quando o timer do leilão expira é informado se ganhou ou se foi superado por outra licitação. Todo o processo é assíncrono, sem recargas de página, mantendo a transição entre estados imperceptível.

CAÇA AO TESOURO

A partir do separador do mapa, o utilizador filtra eventos pelo raio GPS pretendido e abre o detalhe do evento que lhe interessa, onde encontra a descrição, o XP em jogo e o método de validação aceite. Ao chegar fisicamente ao local, valida a sua presença por GPS — caso o evento aceite localização — ou inserindo o código QR exibido no ponto. Após a validação, o XP é atribuído imediatamente e o histórico fica registado em XPLog, contribuindo para a progressão no leaderboard global e desbloqueando, eventualmente, novos níveis de utilizador.

CRIAÇÃO DE UM LEILÃO

O vendedor acede ao Perfil e abre Os Meus Leilões, optando por criar um novo. Preenche o formulário com título, descrição e preço de partida, carrega entre 3 e 15 imagens, define os atributos relevantes em pares chave-valor, escolhe a duração (em horas ou dias) e indica a localização GPS, manualmente ou usando a posição atual. Ao submeter, o leilão fica imediatamente ativo e visível na listagem geral, com contagem decrescente do timer e notificações dirigidas ao vendedor sempre que haja um novo lance ou que o leilão se aproxime do fecho.

REGISTO E ONBOARDING

No primeiro acesso, o utilizador escolhe entre criar conta ou entrar com credenciais existentes. O registo pede nome, email, password e data de nascimento, validando localmente o formato dos campos e a maioridade legal antes de submeter. Confirmada a conta, o utilizador é redirecionado para a homepage com um pequeno tour visual que destaca as zonas principais do produto — listagem, mapa e perfil — para que se familiarize sem fricção.

AVALIAÇÃO PÓS-TRANSAÇÃO

Concluído um leilão, o comprador recebe uma notificação a convidá-lo a avaliar o vendedor. O fluxo apresenta uma escala de cinco estrelas e um campo de comentário opcional. A avaliação é gravada em Review, fica visível no perfil público do vendedor e contribui para a sua reputação, incentivando comportamentos transparentes ao longo da comunidade.

Wireframes de Baixa Fidelidade

Os wireframes estabeleceram a estrutura e o ritmo visual antes de qualquer decisão estética, servindo de base de discussão para alinhar a equipa quanto a prioridades e hierarquia de informação em cada ecrã.

METODOLOGIA

O processo começou com sketches em papel, rapidamente convertidos em wireframes digitais de baixa fidelidade construídos em Figma. A escolha pela baixa fidelidade foi deliberada — interessava discutir o que cada ecrã teria, e não como ficaria, evitando que detalhes visuais distraíssem das decisões estruturais. As versões aprovadas serviram de mapa para o Design System e para os mockups de alta fidelidade construídos posteriormente, garantindo continuidade entre as duas fases de prototipagem.

ECRÃS COBERTOS

Foram desenvolvidos wireframes para a homepage, listagem de leilões, detalhe de leilão, perfil de utilizador, gestão de "Os Meus Leilões" e mapa da Caça ao Tesouro. Cada ecrã foi modelado nas versões desktop e mobile, garantindo que a hierarquia se mantém coerente em ambos os contextos. Componentes recorrentes — barra de navegação, card de produto, painel de licitação — foram identificados nesta fase e promovidos a peças do Design System, evitando duplicação e reforçando a consistência entre fluxos.

DECISÕES DE LAYOUT

A homepage privilegia a descoberta: leilões em destaque, categorias prominentes e ponto de entrada visível para a Caça ao Tesouro. A listagem assume um grid responsivo com filtros à esquerda (em desktop) ou no topo (em mobile). O detalhe de leilão coloca a galeria de imagens à esquerda e o painel de lances à direita, com o chat acessível por tab. O perfil é organizado em sub-secções por menu lateral, e o mapa ocupa quase a totalidade do viewport, com filtros e detalhe do ponto sobrepostos como overlays.

ITERAÇÃO COM A EQUIPA

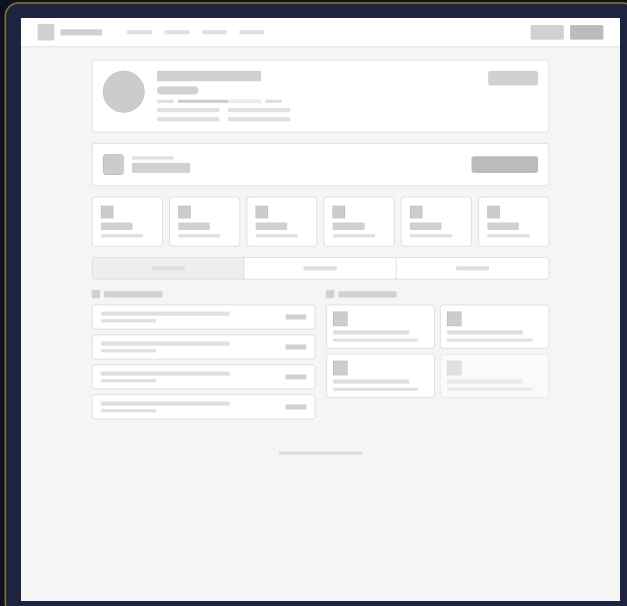
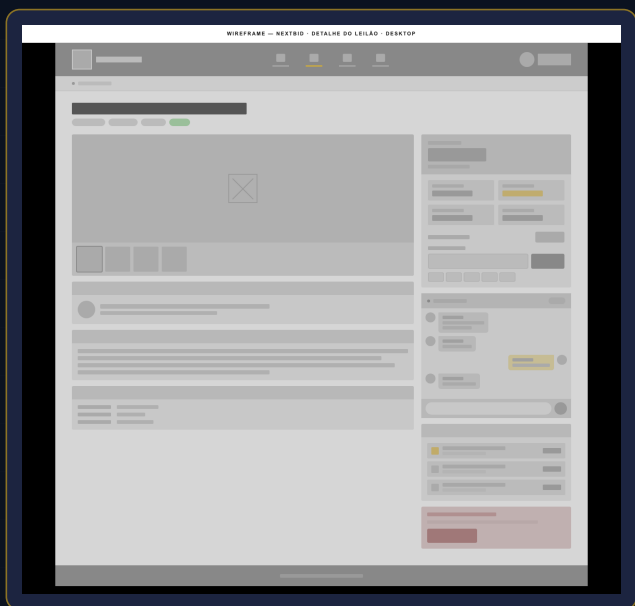
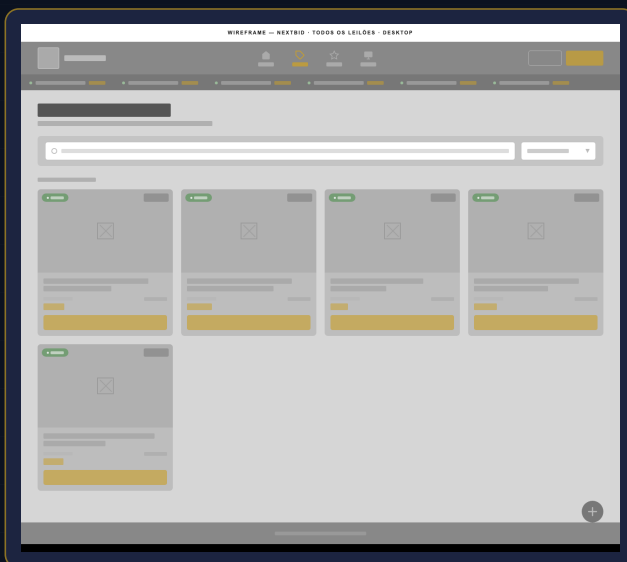
Cada wireframe foi revisto colectivamente em sessões dedicadas, onde se discutiu o significado visual de cada zona e se ajustaram dúvidas de hierarquia. As alterações mais significativas surgiram do exercício de Tree Testing, que evidenciou redundâncias entre os blocos de "Leilões Ativos" e "Os Meus Leilões"; a partir dessa observação, ambos foram reescritos com titulação distinta e ícones próprios. Esta abordagem iterativa, ainda na fase de wireframe, evitou retrabalho dispendioso já com componentes finais aplicados.

TRANSIÇÃO PARA ALTA FIDELIDADE

Quando os wireframes estabilizaram, a equipa avançou para o Design System e para os mockups de alta fidelidade. A transição foi simples porque cada componente tinha já um nome, uma posição e uma função; bastou aplicar tipografia, cores e estados. Os mockups apresentados nas páginas seguintes são consequência direta destes wireframes, sem alterações estruturais, apenas com a aplicação coerente do sistema visual definido em Figma.

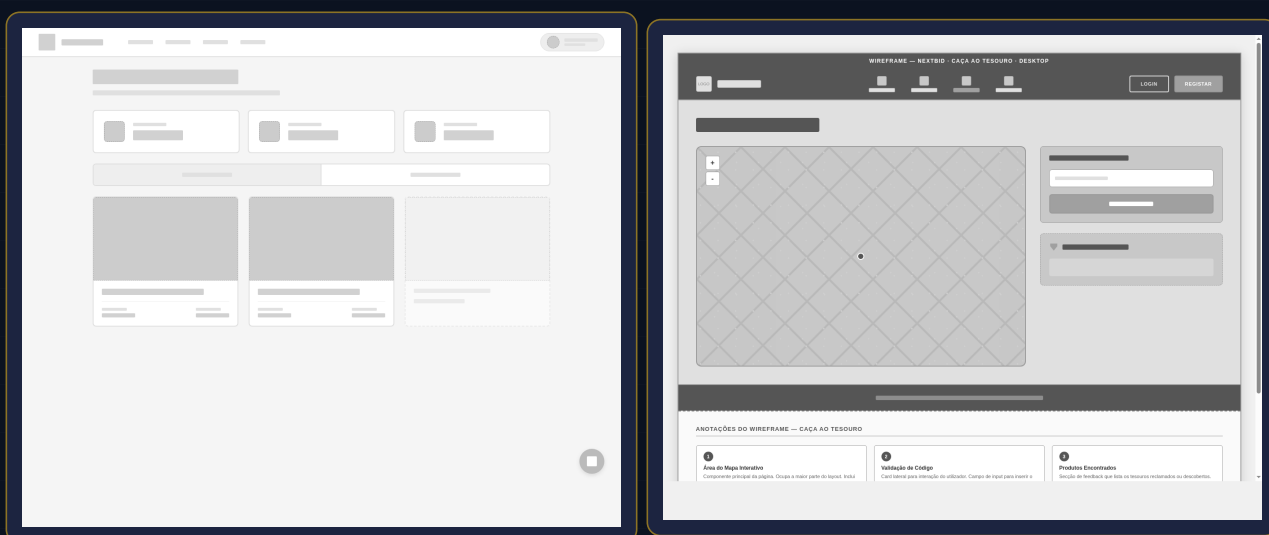
Ecrãs de Baixa Fidelidade

Quatro dos seis ecrãs de baixa fidelidade desenvolvidos: listagem de leilões, homepage com destaques, detalhe de leilão (galeria + painel de lances) e perfil do utilizador.



Mapa & Os Meus Leilões

Mapa da Caça ao Tesouro com integração geográfica e o ecrã de gestão dos leilões publicados pelo utilizador.



Design System & Interfaces

O Design System foi construído em Figma com base em três decisões fundamentais: tipografia com personalidade, paleta navy & gold e uma grelha de espaçamento de 8 pixels que percorre toda a aplicação.

PRINCÍPIOS E ABORDAGEM

O sistema parte de uma estética sóbria e de leilão clássico — cor escura como pano de fundo, dourado como acento — e reinterpreta-a para o contexto digital, com componentes adaptados a interações modernas (hover, focus, estados de loading e erro). Cada componente foi desenhado nas suas variantes (default, hover, active, disabled) e documentado com regras de utilização para que qualquer elemento da equipa o possa replicar sem ambiguidades.

COMPONENTES REUTILIZÁVEIS

O catálogo inclui Product Card (representação compacta de um leilão na listagem), Bid Panel (caixa de licitação com histórico, valor mínimo e botão de submissão), Navigation Bar (com estados autenticado e não autenticado), Form Inputs (texto, número, data, upload de imagem), Modals para confirmações e formulários secundários, Notification Badge para alertas no header, XP Progress Bar para a barra de progresso do utilizador, Star Rating para avaliações, Avatar circular e Map Markers personalizados para os eventos de Caça ao Tesouro.

TIPOGRAFIA

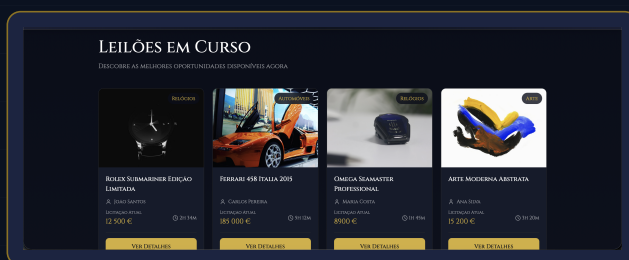
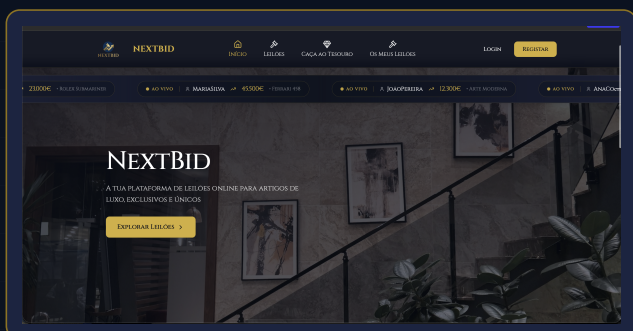
A hierarquia tipográfica usa três famílias com papéis distintos. EB Garamond, uma serif clássica, é reservada aos headings principais e dá ao produto a sua autoridade de leilão. Inter, uma sans-serif legível e neutra, ocupa todo o body, garantindo conforto de leitura em blocos extensos. JetBrains Mono surge em códigos, identificadores e dados técnicos, mantendo a distinção visual entre conteúdo editorial e informação estruturada.

PALETA CROMÁTICA

A base #0B1220 (navy profundo) cobre o pano de fundo da aplicação. As superfícies elevadas — cards, modais, tooltips — usam #151B2B para destacar conteúdo sobre o fundo. O dourado #D4AF37 reserva-se para ações críticas (botão de licitar, links de afirmação) e para acentos discretos em ícones e separadores. O branco puro #FFFFFF é usado em texto principal sobre fundos escuros, maximizando o contraste e mantendo o produto acessível.

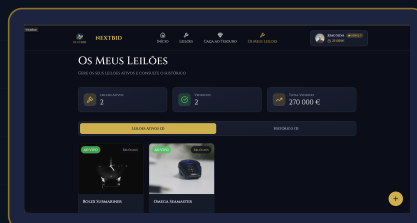
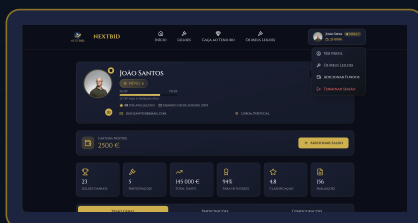
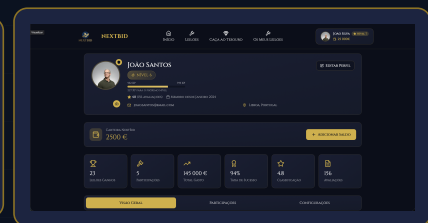
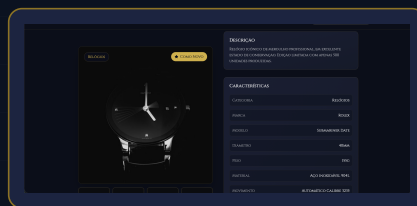
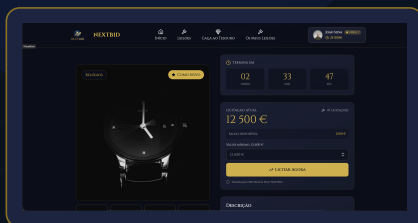
Listagem & Detalhe

Homepage com leilões em destaque e ecrã de detalhe com chat e painel de licitações. Os mockups concretizam o Design System e servem de referência direta para a implementação frontend.



Perfil, Carteira & Caça ao Tesouro

Detalhe com histórico de lances, dashboard de perfil, gestão de Os Meus Leilões, ecrã de carteira com adição de fundos, e a Caça ao Tesouro nas vistas de menu e mapa.



Base de Dados

A persistência assenta numa base de dados relacional MySQL/MariaDB acedida exclusivamente via PDO, normalizada até à 3ª Forma Normal e composta por 14 tabelas que cobrem a totalidade do domínio modelado.

DECISÕES DE DESIGN

Os tokens de sessão foram separados numa tabela dedicada (auth_tokens), o que viabiliza o suporte multi-dispositivo e a revogação seletiva de acessos sem afetar a tabela de utilizadores. Os atributos dinâmicos dos produtos (product_attribute) seguem o padrão chave-valor, permitindo descrever leilões heterogéneos sem alterar o schema sempre que surge uma nova categoria. A carteira interna foi modelada como ledger imutável: cada movimento é uma linha em transactions e o saldo do utilizador é calculado por agregação, garantindo total auditabilidade das operações financeiras.

GAMIFICAÇÃO E GEOLOCALIZAÇÃO

O sistema de XP foi desenhado em duas tabelas — xp_logs guarda o histórico cronológico de ganhos, e xp_level mantém os limiares de cada nível como dados, fora do código. Esta separação permite rebalancear a curva de progressão alterando apenas registos da base de dados, sem novos deploys. As coordenadas GPS são armazenadas em colunas DECIMAL com precisão suficiente para uso urbano e são consultadas pela fórmula de Haversine no cálculo de distâncias entre o utilizador e leilões ou eventos próximos.

TABELAS PRINCIPAIS

O conjunto de 14 tabelas inclui users, auth_tokens, category, product, product_attribute e product_image para o núcleo de utilizadores e leilões; bid e transactions para lances e movimentos financeiros; gamification, gamification_claim, xp_logs e xp_level para a Caça ao Tesouro e progressão; e notifications e review para alertas e avaliações. Cada tabela tem chave primária auto-incrementada, chaves estrangeiras explícitas com regras ON DELETE / ON UPDATE adequadas, e índices nos campos mais consultados.

ACESSO SEGURO E DOCUMENTAÇÃO

Todo o acesso à base de dados passa por PDO com prepared statements, eliminando por construção qualquer risco de SQL injection. As passwords são guardadas em bcrypt com fator de custo apropriado. O schema completo, scripts SQL de criação, dados de teste e exemplos de queries frequentes encontram-se documentados em detalhe no ficheiro relatório_BD.md, complementar a este relatório.

Documentação da API REST

A camada de comunicação foi formalizada como uma API REST stateless com especificação OpenAPI 3.0 e autenticação por token Bearer, garantindo que qualquer cliente — web, mobile ou Postman — pode dialogar com o sistema sob as mesmas regras.

CONVENÇÕES

Todos os endpoints aceitam e devolvem JSON, com a única exceção dos endpoints de upload de imagem, que recorrem a multipart/form-data. A autenticação é feita pelo header Authorization com o esquema Bearer e um token de 64 caracteres emitido pelo servidor no momento do login. Cada resposta segue um envelope coerente: { "success": true, "data": {...} } em caso de sucesso, ou { "success": false, "error": "..." } em caso de erro, com mensagens descritivas e códigos HTTP apropriados — 200 para sucesso, 400 para erro de validação, 401 para autenticação, 403 para autorização, 404 para recurso ausente e 409 para conflito.

AUTENTICAÇÃO E CICLO DE SESSÃO

O cliente envia credenciais para /auth/login.php e recebe um token associado ao dispositivo. Esse token deve acompanhar todas as chamadas subsequentes e tem prazo de expiração configurável. O endpoint /auth/logout.php invalida apenas a sessão atual; /auth/logout_all.php elimina todos os tokens emitidos para o utilizador, sendo útil em casos de comprometimento de credenciais ou reset proactivo de acessos. Cada token é gerado com entropia criptográfica e guardado em auth_tokens, com timestamp de criação e prazo de validade próprios.

IDEMPOTÊNCIA E VERSIONAMENTO

As operações de leitura — get_active, get_by_id, get_balance — são idempotentes por natureza e podem ser repetidas com segurança. As operações de escrita são desenhadas para falhar cedo: validações de valor, estado e propriedade do recurso ocorrem antes de qualquer mutação. A API foi pensada para suportar versionamento futuro através do prefixo do path (por exemplo, /v2/bids/place_bid.php), permitindo evoluir o contrato sem partir clientes legados.

EXEMPLO — COLOCAR UMA LICITAÇÃO

Para licitar num leilão existente, o cliente faz POST /bids/place_bid.php com o header Authorization: Bearer <token>, Content-Type application/json e o corpo {"product_id": 42, "amount": 450.00}. O servidor valida o token, confirma que o produto está ativo, verifica se o valor é superior ao lance atual e devolve { "success": true, "data": { "bid_id": 87, "amount": 450.00, "is_highest": true } }. Em caso de lance abaixo do mínimo ou de leilão expirado, devolve um erro descritivo com HTTP 400 ou 409, mantendo a consistência da base de dados.

Endpoints & Segurança

Os endpoints estão organizados por módulo, espelhando o domínio do sistema. Cada módulo agrupa as operações relevantes e mantém a sua própria pasta no backend, facilitando a manutenção e a evolução independente de cada área.

ENDPOINTS POR MÓDULO

O módulo Auth concentra register, login, logout e logout_all. Auctions cobre create, get_active, get_by_id, get_by_seller, get_by_winner e cancel. Bids agrupa place_bid, get_by_user e get_by_product. Attributes e Images expõem operações CRUD especializadas para os atributos e imagens dos produtos. Transactions disponibiliza get_balance, deposit e get_history. Gamification inclui get_nearby, join_hunt, claim_point, claim_with_code, get_claimed e create_event. Categories oferece get_all, create, update e delete. Chat tem get_by_product e send. Reviews mantém get_for_seller e create. Users expõe get_profile, update_profile, update_photo, get_xp_history, get_level e get_leaderboard. Notifications fecha o conjunto com get_all, mark_read e delete.

VALIDAÇÃO E PREPARED STATEMENTS

A defesa começa na entrada: todos os parâmetros recebidos do cliente são validados quanto a tipo, gama de valores e presença obrigatória antes de qualquer operação na base de dados. As consultas SQL são exclusivamente parametrizadas via PDO Prepared Statements, eliminando por construção qualquer risco de injection. Para uploads, é validado o tipo MIME real do ficheiro, a extensão e o tamanho máximo de 5 MB, e os ficheiros são renomeados antes de serem gravados para evitar conflitos e enumeração.

AUTENTICAÇÃO E AUTORIZAÇÃO

As passwords são guardadas em bcrypt com fator de custo elevado, e os tokens de sessão são gerados aleatoriamente com 64 caracteres e prazo de expiração. Cada endpoint sensível verifica se o token recebido é válido, se ainda não expirou e se pertence ao utilizador que se identifica na operação. Os endpoints administrativos — gestão de categorias e criação de eventos de gamificação — verificam adicionalmente o role do utilizador, recusando o pedido com HTTP 403 caso este não tenha permissões suficientes.

TRATAMENTO DE ERROS

O backend distingue claramente entre erros previstos e erros inesperados. Erros previstos — lance abaixo do mínimo, leilão expirado, saldo insuficiente, token inválido — devolvem sempre o envelope { "success": false, "error": "..." } com mensagem dirigida ao utilizador e código HTTP apropriado. Erros inesperados são capturados num bloco geral, registados em log do servidor com contexto, e devolvidos como HTTP 500 sem expor detalhes internos, protegendo a aplicação contra fugas de informação sensível.

BOAS PRÁTICAS ADICIONAIS

A API recusa pedidos sem o header Authorization quando este é obrigatório, sem nunca retornar pistas sobre o motivo concreto da rejeição. Os tempos de resposta são uniformes em login com email errado e em login com password errada, mitigando ataques de enumeração. Os endpoints de listagem suportam paginação por offset e limite, evitando que pedidos maliciosos sobrecarreguem o servidor. Em iteração futura, está prevista a introdução de rate limiting por IP nos endpoints mais sensíveis (login, registo, lance).

Esquema da Solução Técnica

A arquitetura segue o padrão cliente-servidor tradicional em três camadas, com responsabilidades claras e fronteiras bem definidas — uma escolha que prioriza a previsibilidade, a manutenção e o alinhamento com as ferramentas disponíveis no ambiente XAMPP/MAMP.

CAMADA DE CLIENTE

O frontend é construído em HTML5 semântico, CSS3 com variáveis para a paleta do Design System e JavaScript Vanilla, sem frameworks. Toda a comunicação com o servidor passa pela Fetch API, que é nativa, suporta promises e elimina a necessidade de bibliotecas externas. As páginas principais — Homepage, Leilões, Perfil, Mapa — são entregues como documentos HTML estáticos que carregam módulos JavaScript responsáveis por consumir a API e renderizar o estado atualizado em tempo real.

CAMADA DE BACKEND

O backend é um conjunto de scripts PHP organizados por módulo, cada um com a sua pasta e os seus endpoints (auth, auctions, bids, wallet, gamification, users, etc.). Cada endpoint segue um esqueleto comum: valida o token de sessão, lê os parâmetros do pedido, valida-os, executa a operação na base de dados via PDO e devolve uma resposta JSON. A escolha de PHP foi pragmática — é maduro, ubíquo no hosting e perfeitamente adequado à dimensão do projeto.

CAMADA DE DADOS

A persistência fica a cargo de MySQL ou MariaDB (compatíveis e intercambiáveis) com 14 tabelas normalizadas até à 3ª Forma Normal. O acesso é exclusivamente via PDO com prepared statements, e as transações multi-tabela — por exemplo, ao licitar (que envolve bid + transactions) — são protegidas por BEGIN/COMMIT, garantindo integridade ACID.

FLUXO DE DADOS

Numa operação típica, o utilizador interage com a interface e dispara uma chamada Fetch para um endpoint específico. O servidor PHP valida o token, executa a query parametrizada na base de dados, recebe o resultado, monta o envelope JSON e devolve a resposta. O frontend consome a resposta, atualiza apenas as áreas relevantes do DOM e mantém o utilizador no contexto, sem recargas completas de página — uma experiência fluida que cumpre os princípios de uma aplicação web moderna mesmo sem recurso a frameworks reativos.

Stack Tecnológico

Cada peça da stack foi escolhida deliberadamente, ponderando a dimensão do projeto, a maturidade da tecnologia e a sua compatibilidade com o ambiente XAMPP/MAMP usado em desenvolvimento.

FRONTEND E MAPAS

O frontend usa HTML5, CSS3 e JavaScript Vanilla, sem frameworks reativos. Esta escolha tem duas razões: por um lado, mantém a aplicação leve e zero-dependencies, sem custo de bundle nem ciclos de build; por outro, força a equipa a compreender as APIs nativas do browser, que aliás são suficientes para a complexidade visada. A comunicação HTTP é feita pela Fetch API e os mapas são integrados com Leaflet.js, uma biblioteca open-source extremamente leve que se adapta bem à estética definida no Design System.

BACKEND E DADOS

No backend, PHP é a opção natural pela maturidade da plataforma e pela ubiquidade do hosting partilhado. O acesso à base de dados é feito por PDO, que oferece prepared statements e uma API uniforme para vários sistemas relacionais. A API segue o estilo REST com payloads em JSON e está formalizada em OpenAPI 3.0, mantendo a interoperabilidade com qualquer cliente. A base de dados em si é MySQL ou MariaDB, ambas relacionais, ACID e largamente compatíveis entre si — o produto pode ser servido por qualquer uma sem alterações.

AMBIENTE, DESIGN E COLABORAÇÃO

O servidor local de desenvolvimento usa XAMPP ou MAMP, que entregam Apache, PHP e MySQL pré-configurados num único bundle. O design e a prototipagem foram feitos em Figma, plataforma escolhida pela colaboração em tempo real e pelo suporte a Design Systems com componentes e variantes. O código vive em Git e GitHub, com branches dedicados a cada frente de trabalho e pull requests revistos pela equipa antes de qualquer merge.

TESTES E QUALIDADE

A API é testada continuamente com Postman, onde existem coleções organizadas por módulo e cenário — auth feliz, auth com token expirado, lance válido, lance abaixo do mínimo, criação de leilão com imagens, etc. Estes testes funcionam como uma rede de segurança que permite evoluir o backend com confiança e validar novas funcionalidades antes de as expor ao frontend.

Estado Atual & Próximos Passos

A equipa dispõe de uma versão Alfa onde o fluxo principal de dados pode ser validado de ponta a ponta. O trabalho realizado nesta fase deixa o produto pronto para uma próxima iteração centrada em refinamento, completude e feedback de utilizadores reais.

O QUE ESTÁ OPERACIONAL

A versão Alfa está em ~85% das funcionalidades core e ~70% das funcionalidades secundárias. O frontend tem a estrutura base implementada e cobre os principais ecrãs do produto. O backend está ligado à base de dados e expõe os endpoints essenciais para o ciclo de vida de um leilão. A comunicação entre frontend e backend foi validada via Postman e via navegador, com chamadas Fetch a chegar à base de dados e o estado a refletir-se no DOM sem recargas. Em concreto, é possível registar um utilizador, autenticá-lo, listar leilões, abrir o detalhe e submeter um lance — o caminho crítico identificado como critério de Alfa está atingido.

PRÓXIMOS PASSOS

A próxima iteração foca-se no refinamento dos algoritmos de licitação e na introdução de timers cronometrados de fecho que disparem automaticamente o vencedor e as transações associadas. A integração completa do módulo geográfico com Leaflet.js trará a visualização rica de leilões e eventos no mapa, com markers personalizados e raios dinâmicos. O backoffice ganhará um fecho estatístico — médias de lances, leilões por categoria, evolução temporal — e serão conduzidos testes rigorosos de usabilidade com utilizadores finais. A camada de segurança será reforçada com rate limiting por IP em endpoints sensíveis, mitigando ataques de brute force e abuso da API.

CONCLUSÃO

A Fase II cumpriu os seus objetivos centrais. Foi possível consolidar a arquitetura visual através do Design System, implementar a base funcional e de dados do sistema NextBid e materializar as ideias da Fase I em protótipos de alta fidelidade. Mais importante do que isso, ficou estabelecida com sucesso a infraestrutura técnica que liga o frontend ao backend através de chamadas assíncronas, o que abre caminho a uma Fase III dedicada à experiência fina do utilizador, à robustez operacional e ao polimento dos detalhes que separam um protótipo funcional de um produto pronto para demonstração pública.